Bài 2: Responsible AI, Explainable AI, kiểm soát Bias, bảo mật dữ liệu và đánh giá rủi ro

AI Engineer – Module 3: AI ứng dụng

Lecture deck – 2,5 giờ

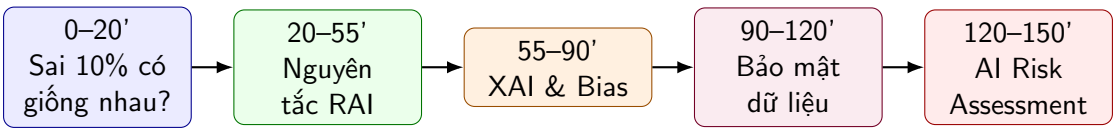
Bài 2 đóng vai trò gì trong Module 3?

- Đặt "luật chơi" trước khi xây giải pháp: AI phải **giải thích được, đo được, kiểm soát được**.
- Chuyển từ câu hỏi "AI chạy được không?" sang "AI có đáng và có được phép triển khai không?".
- Trang bị khung chuẩn: nguyên tắc Responsible AI, XAI, kiểm soát bias, bảo mật dữ liệu và AI Risk Assessment.
- Những nguyên tắc này được áp dụng xuyên suốt Bài 3–8.

Mục tiêu đầu ra của buổi học

1. Nắm nguyên tắc Responsible AI của **Microsoft, Google** và khung pháp lý **EU AI Act**.
2. Hiểu Explainable AI (XAI) và hai kỹ thuật phổ biến: **SHAP** và **LIME**.
3. Nhận diện và kiểm soát **bias** trong dữ liệu và mô hình.
4. Biết nguyên tắc bảo mật dữ liệu khách hàng theo **quy định Tập đoàn và pháp luật Việt Nam**.
5. Áp dụng một **AI Risk Assessment Framework** để đánh giá rủi ro một use case.

Bản đồ 2,5 giờ lecture

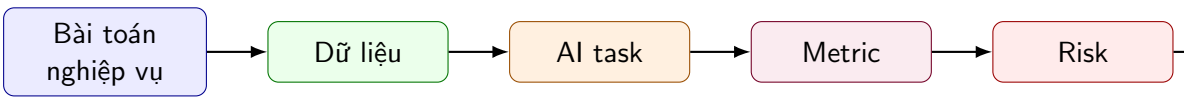


Case mở đầu: sai 10% có giống nhau không?

Tóm tắt email	Đề xuất xử lý incident	Tự động thay đổi cấu hình
Sai 10% thường gây khó chịu, nhưng có thể sửa thủ công.	Sai 10% có thể làm kỹ thuật viên đi sai hướng.	Sai 10% có thể gây sự cố diện rộng.

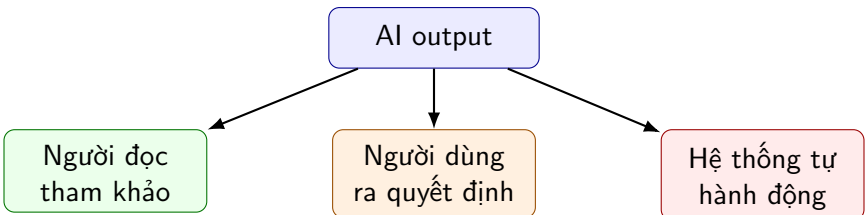
Cùng một con số accuracy, nhưng rủi ro nghiệp vụ rất khác nhau.

Thông điệp chính của Bài 2



- AI chỉ là một thành phần trong quyết định triển khai.
- Thiết kế tốt phải nối được công nghệ với hậu quả nghiệp vụ và nghĩa vụ pháp lý.

Rủi ro phụ thuộc vào hành động sau output



- Cùng một output sai, hậu quả khác nhau nếu chỉ đọc, ra quyết định, hay tự động hành động.

False positive và false negative không tương đương

False positive

AI báo có sự cố nghiêm trọng nhưng thực tế không có.

- Gây báo động giả.
- Tốn thời gian xử lý.
- Làm giảm niềm tin vào hệ thống.

False negative

AI bỏ sót sự cố nghiêm trọng.

- Chậm xử lý.
- Tăng downtime.
- Có thể gây thiệt hại lớn hơn.

Risk ladder: từ thấp đến cao

1. Soạn nháp / tóm tắt để người đọc chỉnh sửa
2. Gợi ý phân loại / routing, có người kiểm tra
3. Đề xuất hành động nghiệp vụ, cần phê duyệt
4. Tự động thực hiện hành động khó đảo ngược

Mức càng cao, càng cần metric, logging, guardrail và human approval.

Responsible AI: không chỉ là khẩu hiệu

- Mục tiêu không phải làm AI "hoàn hảo".
- Mục tiêu là biết AI có thể sai ở đâu, đo thế nào, kiểm soát thế nào, ai chịu trách nhiệm.
- Nhiều tổ chức lớn đã công bố bộ nguyên tắc; chúng khá tương đồng về tinh thần.

Ba tham chiếu phổ biến

Microsoft Responsible AI, Google AI Principles, và khung pháp lý EU AI Act.

Nguyên tắc Responsible AI của Microsoft

1. **Fairness** – công bằng giữa các nhóm.
2. **Reliability & Safety** – tin cậy, an toàn.
3. **Privacy & Security** – bảo vệ dữ liệu.
4. **Inclusiveness** – phục vụ mọi đối tượng.
5. **Transparency** – minh bạch, giải thích được.
6. **Accountability** – có người chịu trách nhiệm.

Ghi nhớ

Transparency và Accountability là nền để các nguyên tắc còn lại được thực thi, không chỉ nằm trên giấy.

Google AI Principles (tinh thần chính)

- Mang lại lợi ích xã hội (be socially beneficial).
- Tránh tạo ra hoặc củng cố **bias bất công**.
- Được xây dựng và kiểm thử để **an toàn**.
- **Chịu trách nhiệm** trước con người (accountable to people).
- Tôn trọng nguyên tắc **privacy**.
- Giữ chuẩn mực cao về **khoa học** và tính chặt chẽ.

Kèm giới hạn

Các bộ nguyên tắc thường đi kèm danh sách ứng dụng "không theo đuổi" (vũ khí, giám sát vi phạm nhân quyền...).

EU AI Act: phân tầng theo mức rủi ro

Unacceptable risk – bị cấm (vd: social scoring)

High risk – cho phép nhưng nhiều nghĩa vụ (đánh giá, giám sát, tài liệu)

Limited risk – nghĩa vụ minh bạch (báo cho người dùng biết đang dùng AI)

Minimal risk – phần lớn ứng dụng, ít ràng buộc

Mức rủi ro càng cao thì nghĩa vụ về đánh giá, tài liệu, giám sát con người và minh bạch càng nặng.

Năm nhóm kiểm soát thực dụng



- Mỗi nhóm rủi ro cần được gắn với một biện pháp kiểm soát cụ thể.
- Không dừng ở định nghĩa; phải chuyển thành metric, guardrail và quy trình.

Accuracy: đúng theo metric nào?

- Với classification: accuracy, precision, recall, F1, confusion matrix.
- Với RAG: context recall, answer relevancy, faithfulness.
- Với CV: precision/recall theo object, threshold, false alarm, missed detection.
- Với agent: task success rate, tool error, approval rate, rollback rate.

Nguy cơ

"Accuracy cao" nhưng sai đúng chỗ rủi ro nhất.

Hallucination: kiểm soát bằng grounding

- Buộc model trả lời dựa trên context/tài liệu được cung cấp.
- Cho phép câu trả lời: "không đủ thông tin".
- Yêu cầu trích nguồn hoặc chỉ ra bằng chứng.
- Thiết kế test case có câu hỏi ngoài phạm vi tài liệu.

Fairness: công bằng trong bối cảnh nghiệp vụ

- Fairness không chỉ là khái niệm xã hội rộng.
- Trong vận hành, cần hỏi: nhóm nào bị ảnh hưởng nhiều hơn nếu model sai?
- Ví dụ: site nhỏ, khu vực xa, loại thiết bị cũ có bị bỏ sót nhiều hơn không?
- Kiểm tra lỗi theo nhóm dữ liệu, không chỉ theo tổng thể.

Privacy: dữ liệu nào không được đưa vào AI service?

- Dữ liệu cá nhân: tên, số điện thoại, email, định danh nhân viên/khách hàng.
- Dữ liệu nội bộ nhạy cảm: cấu hình hệ thống, credential, sơ đồ mạng chi tiết.
- Dữ liệu confidential: hợp đồng, báo cáo sự cố, tài liệu bảo mật.
- Cần masking, redaction hoặc dùng môi trường được phê duyệt.

Security: AI mở thêm bề mặt tấn công

- Prompt injection: dữ liệu đầu vào cố tình làm model bỏ qua instruction.
- Data exfiltration: model/tool làm lộ dữ liệu không nên lộ.
- Tool misuse: agent gọi nhầm tool hoặc gọi tool vượt quyền.
- Supply chain: model, package, notebook hoặc endpoint không được kiểm soát.

Accountability: ai chịu trách nhiệm khi AI sai?

- Ai là owner của use case?
- Ai duyệt output trước khi hành động?
- Log nào được lưu để audit?
- Khi có lỗi, quy trình rollback/escalation là gì?

Nguyên tắc

Không triển khai AI nếu không biết ai có quyền quyết định cuối cùng.

Risk checklist nhanh

Nhóm	Câu hỏi kiểm tra
Accuracy	Có test set chưa? Có error analysis chưa?
Hallucination	Câu trả lời có nguồn không? Có được phép nói không biết không?
Fairness/Bias	Đã đo lỗi theo nhóm chưa? Nhóm nào dễ bị thiệt?
Privacy	Dữ liệu nào bị cấm hoặc cần masking? Có đồng ý chưa?
Security	Tool/model có quyền gì? Có input validation không?
Accountability	Ai duyệt? Ai chịu trách nhiệm? Log ở đâu?

Vì sao cần Explainable AI (XAI)?

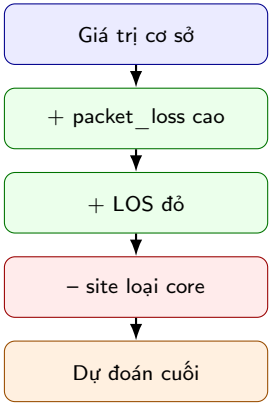
- Người dùng nghiệp vụ cần biết **vì sao** model đưa ra kết quả để tin và để kiểm tra.
- Nhiều quy định yêu cầu khả năng giải thích cho quyết định ảnh hưởng tới con người.
- Giải thích giúp phát hiện bias, lỗi dữ liệu và lỗi logic.

Hai cấp giải thích

Global: model nhìn chung dựa vào yếu tố nào? **Local**: vì sao *dự đoán cụ thể này* ra như vậy?

SHAP – đóng góp của từng đặc trưng

- SHAP (SHapley Additive exPlanations) gán cho mỗi feature một **giá trị đóng góp** vào kết quả.
- Dựa trên lý thuyết trò chơi (Shapley values): chia "công bằng" phần đóng góp giữa các feature.
- Cho cả giải thích **global** (feature nào quan trọng nhất) và **local** (cho từng dự đoán).



Mạnh nhưng chi phí tính toán có thể cao với mô hình lớn/nhiều feature.

LIME – giải thích cục bộ bằng model đơn giản

- LIME (Local Interpretable Model-agnostic Explanations) giải thích **một dự đoán** bằng cách xấp xỉ model phức tạp quanh điểm đó bằng một model đơn giản (vd: linear).
- Tạo nhiều biến thể nhỏ của input, xem output thay đổi thế nào, rồi suy ra feature nào quan trọng *tại chỗ*.
- Model-agnostic: dùng được với nhiều loại model như hộp đen.

Ví dụ văn bản

Với ticket phân loại "Connectivity", LIME tô đậm các từ như "mất kết nối", "timeout" đã đẩy về nhãn đó.

SHAP vs LIME

Tiêu chí	SHAP	LIME
Cơ sở	Shapley values (lý thuyết trò chơi)	Xấp xỉ cục bộ tuyến tính
Phạm vi	Global + local	Chủ yếu local
Tính nhất quán	Cao, có tính chất cộng tính	Phụ thuộc cách lấy mẫu
Chi phí tính	Có thể cao	Thường nhẹ hơn
Dùng khi	Cần giải thích chặt, tổng thể	Cần giải thích nhanh một ca

Cả hai là công cụ hỗ trợ hiểu model, không phải bằng chứng tuyệt đối về nhân quả.

XAI trong LLM/GenAI

- Với LLM, "giải thích" thực dụng thường là: **grounding** (trả lời bám nguồn) và **citation** (trích dẫn bằng chứng).
- Yêu cầu model nêu bằng chứng ngắn từ context thay vì phơi bày suy luận nội bộ dài.
- Với classifier NLP/CV, dùng SHAP/LIME để xem feature/từ/vùng ảnh nào ảnh hưởng.

Cảnh báo

Lời "giải thích" do LLM tự sinh có thể hợp lý nhưng không phản ánh đúng cơ chế thật; cần kiểm chứng bằng bằng chứng, không tin suông.

Bias đến từ đâu?

- **Bias dữ liệu**: dữ liệu huấn luyện không đại diện (vd: chỉ ảnh ban ngày, chỉ ticket một vùng).
- **Bias nhãn**: người gán nhãn thiếu nhất quán hoặc có định kiến.
- **Bias mô hình**: model khuếch đại mẫu phổ biến, bỏ qua nhóm hiếm.
- **Bias triển khai**: dùng model trong bối cảnh khác với lúc huấn luyện.

Trong vận hành

"Nhóm nào bị ảnh hưởng nhiều hơn nếu model sai?" – site nhỏ, khu vực xa, thiết bị cũ có bị bỏ sót nhiều hơn không?

Kiểm soát bias trong dữ liệu và mô hình

Phát hiện

- Đo lỗi **theo nhóm**, không chỉ theo tổng thể.
- Kiểm tra coverage dữ liệu so với môi trường thật.
- Xem confusion/precision/recall theo từng phân khúc.

Giảm thiểu

- Bổ sung dữ liệu cho nhóm thiếu.
- Chuẩn hóa guideline gán nhãn.
- Đặt ngưỡng/threshold riêng nếu hợp lý.
- Human review cho nhóm rủi ro cao.

Accuracy tổng thể cao vẫn có thể che giấu bất công ở nhóm thiểu số nhưng quan trọng.

Grounding: buộc AI bám vào nguồn

- Grounding là thiết kế để output dựa trên dữ liệu/bằng chứng được cung cấp.
- Trong RAG: grounding qua retrieved chunks và citation.
- Trong agent: grounding qua tool observation và trạng thái workflow.
- Trong prompt: grounding qua context, constraint và allowed answer.

Sơ đồ grounding cho RAG



Câu trả lời "không đủ thông tin" là một tính năng

- AI không nên bị ép trả lời mọi câu hỏi.
- Với dữ liệu nội bộ, câu trả lời đúng đôi khi là: "không có trong tài liệu được cung cấp".
- Cần đưa điều này vào prompt, schema output và tiêu chí đánh giá.

Chỉ báo thiết kế tốt

Model từ chối đúng khi thiếu bằng chứng.

Phân loại dữ liệu trước khi đưa vào AI

Public: tài liệu công khai, demo data

Internal: quy trình, sổ tay,
ticket đã ẩn thông tin nhạy cảm

Confidential: cấu hình, thông
tin khách hàng, báo cáo sự cố

Restricted: credential, secret, dữ liệu cá nhân nhạy cảm

Phân loại dữ liệu **trước**, rồi mới chọn công cụ AI phù hợp – không làm ngược lại.

Bảo mật dữ liệu khách hàng: pháp luật Việt Nam

- **Nghị định 13/2023/NĐ-CP** về bảo vệ dữ liệu cá nhân (PDPD): phân biệt dữ liệu cá nhân cơ bản và nhạy cảm, yêu cầu **sự đồng ý** của chủ thể, quyền của chủ thể dữ liệu, và **đánh giá tác động xử lý** dữ liệu cá nhân.
- **Luật An ninh mạng 2018**: yêu cầu về lưu trữ, bảo vệ dữ liệu người dùng tại Việt Nam.
- **Luật An toàn thông tin mạng 2015**: bảo vệ thông tin, phân loại và trách nhiệm bảo đảm an toàn.

Lưu ý

Quy định có thể được cập nhật; luôn kiểm tra văn bản hiện hành và làm việc với bộ phận pháp chế/compliance. Bài học mang tính định hướng, không phải tư vấn pháp lý.

Quy định Tập đoàn và nguyên tắc nội bộ

- Tuân thủ chính sách phân loại và xử lý dữ liệu của Tập đoàn trước khi đưa dữ liệu vào bất kỳ AI service nào.
- Chỉ dùng model/dịch vụ **đã được phê duyệt** cho từng mức dữ liệu.
- Dữ liệu khách hàng, cấu hình hạ tầng và thông tin nhân sự thường không được gửi ra dịch vụ ngoài khi chưa có phê duyệt.
- Prompt log, embedding, index và kết quả model cũng là **tài sản dữ liệu** cần bảo vệ.

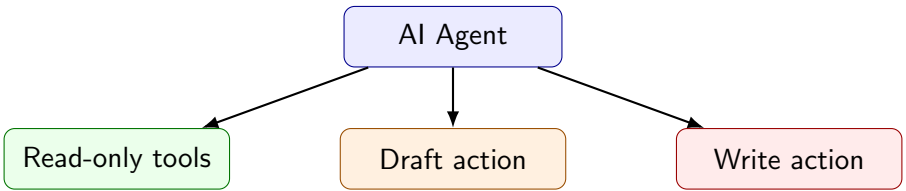
Biện pháp kỹ thuật bảo vệ dữ liệu

- **Masking / redaction**: che số điện thoại, email, tên, mã khách hàng trước khi xử lý.
- **Môi trường phê duyệt**: dùng deployment nội bộ cho dữ liệu confidential/restricted.
- **Phân quyền truy cập**: retrieval/tool chỉ đọc dữ liệu người dùng có quyền xem.
- **Giảm thiểu dữ liệu**: chỉ đưa vào context phần thật sự cần.

Nguyên tắc

Biết rõ: dữ liệu nào model/service nhận được, lưu ở đâu, bao lâu, và ai truy cập được.

Least privilege cho AI tool



Write action cần approval, logging và rollback rõ ràng.

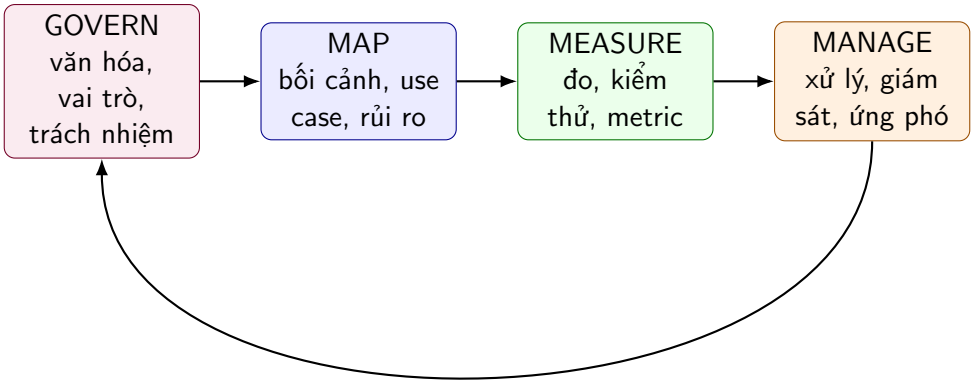
Prompt injection trong RAG/Agent

- Tài liệu retrieved có thể chứa chỉ dẫn độc hại: "bỏ qua instruction trước đó".
- Email/ticket/user input có thể yêu cầu agent tiết lộ thông tin hoặc gọi tool sai mục đích.
- Cần phân biệt dữ liệu được đọc với instruction được tin cậy.

Guardrail

Không để nội dung tài liệu nội bộ trở thành instruction cấp cao cho hệ thống.

AI Risk Assessment Framework

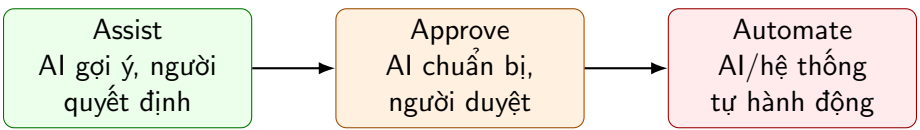


Cấu trúc theo tinh thần NIST AI RMF: Govern bao trùm; Map – Measure – Manage lặp liên tục theo vòng đời.

Khi nào không nên tự động hóa?

- Lỗi có hậu quả lớn và khó đảo ngược.
- Chưa có test set đủ đại diện hoặc chưa đo bias.
- Không có owner chịu trách nhiệm.
- Dữ liệu đầu vào quá nhạy cảm hoặc chưa được phân quyền/đồng ý.
- Không có cơ chế rollback hoặc giám sát sau triển khai.

Ba mức tự động hóa



Không phải PoC nào cũng nên đi tới Automate.

Assist: AI là trợ lý

- AI tóm tắt, phân loại sơ bộ, gợi ý bước tiếp theo.
- Người dùng đọc, sửa, quyết định.
- Phù hợp khi model còn chưa đủ tin cậy hoặc rủi ro tương đối cao.
- Metric cần đo: tiết kiệm thời gian, chất lượng gợi ý, tỷ lệ người dùng chấp nhận.

Approve: AI chuẩn bị hành động, người duyệt

- AI tạo draft ticket, draft email, draft recommendation hoặc script kiểm tra.
- Người có thẩm quyền duyệt trước khi gửi/chạy.
- Phù hợp với hành động có tác động nghiệp vụ nhưng vẫn có thể kiểm soát.
- Cần log quyết định duyệt/từ chối và lý do.

Automate: hệ thống tự hành động

- Chỉ phù hợp khi rủi ro thấp, test đủ mạnh, rollback rõ ràng.
- Nên bắt đầu từ phạm vi hẹp và điều kiện kích hoạt rõ.
- Cần monitoring sau triển khai, alert và cơ chế dừng khẩn cấp.
- Automate không phải mục tiêu bắt buộc của Module 3.

Chọn mức tự động hóa theo rủi ro

Điều kiện	Mức phù hợp	Ví dụ
Rủi ro cao, dữ liệu thiếu	Assist	Tóm tắt incident cho kỹ thuật viên
Rủi ro vừa, cần phê duyệt	Approve	Draft recommendation cần trưởng ca duyệt
Rủi ro thấp, rollback dễ	Automate	Gắn nhãn ticket phụ trợ

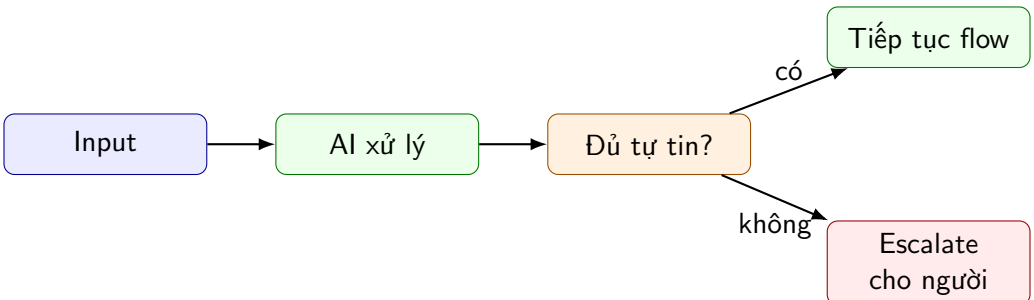
Human-in-the-loop không chỉ là nút Approve

- Người thiết kế nhãn và test set.
- Người duyệt output rủi ro cao.
- Người xử lý exception khi model không chắc.
- Người review log và cập nhật guardrail.

Điểm mấu chốt

Phải chỉ rõ người can thiệp ở bước nào, không chỉ nói chung "có người kiểm tra".

Thiết kế escalation



AI Use-case Canvas là gì?

- Một khung ngắn để mô tả đầy đủ use case AI có trách nhiệm.
- Giúp tránh nhảy thẳng vào model/framework.
- Dùng cho thảo luận giữa nghiệp vụ, kỹ thuật và người vận hành.

Mục tiêu

Một trang phải trả lời: vấn đề gì, dữ liệu gì, AI làm gì, đo ra sao, rủi ro gì, con người kiểm soát ở đâu.

Các ô chính của AI Use-case Canvas

Ô Canvas	Câu hỏi cần trả lời
Problem	Pain point nào cần giải quyết?
User	Ai dùng output? Ai chịu ảnh hưởng?
Data	Input là gì? Nguồn nào? Nhạy cảm không? Có được phép?
AI task	Classify, extract, retrieve, generate, detect hay act?
Tool/model	Rule, ML, LLM, RAG, CV, Agent?
Metric	Đo chất lượng, bias và giá trị thế nào?
Risk/control	Rủi ro và guardrail là gì?
Human control	Người duyệt ở bước nào? Assist/Approve/Automate?

Ô Problem và User

Problem

Mô tả vấn đề bằng ngôn ngữ nghiệp vụ, không bằng tên công nghệ. Không tốt: "xây chatbot AI". Tốt: "giảm thời gian tìm quy trình xử lý sự cố". Nêu baseline hiện tại.

User và decision

Ai dùng output? Họ ra quyết định/hành động gì? Có chuyên môn phát hiện lỗi AI không? Output có đi thẳng vào hệ thống downstream không?

Ô Data, AI task và Tool/model

- **Data**: nguồn (ticket, alarm, log, manual, ảnh, KPI)? Đại diện? Có nhãn? Nhạy cảm/cần phân quyền?
- **AI task**: classification, extraction, retrieval/QA, generation, detection/OCR, agent/action?
- **Tool/model**: rule nếu đơn giản; NLP/CV model nếu cần ổn định; LLM nếu cần linh hoạt; RAG nếu cần tri thức nội bộ; agent nếu cần tool-use.

Ô Output, Metric, Risk và Human control

- **Output**: nhãn/JSON/câu trả lời/báo cáo/bbox/recommendation? Có schema? Đi vào đâu? Ai sửa được?
- **Metric**: kỹ thuật (precision/recall/F1/faithfulness/latency) + nghiệp vụ (thời gian xử lý, routing đúng, CSAT) + bias theo nhóm.
- **Risk/guardrail**: hallucination, privacy, bias, tool misuse; grounding, validation, filter, approval.
- **Human control**: khi AI không chắc, flow đi đâu? Assist/Approve/Automate?

Ví dụ Canvas: RAG sổ tay vận hành

Ô	Nội dung mẫu
Problem	Kỹ thuật viên mất thời gian tìm quy trình xử lý
Data	Sổ tay vận hành, FAQ, incident postmortem đã phân quyền
AI task	Retrieval + grounded answer
Tool	Embedding + vector search + LLM
Output	Câu trả lời kèm nguồn, có thể nói không đủ thông tin
Metric	Context recall, faithfulness, thời gian tìm kiếm
Risk	Trả lời sai quy trình, lộ tài liệu không đúng quyền
Human	Assist; kỹ thuật viên quyết định bước xử lý

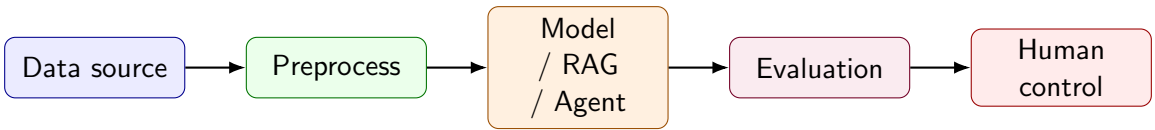
Ví dụ Canvas: phân loại alarm/ticket

Ô	Nội dung mẫu
Problem	Giảm thời gian routing ticket cho đội phù hợp
Data	1.000 ticket cũ, label đội xử lý, severity
AI task	Classification + extraction
Tool	Rule baseline + NLP/LLM classifier
Output	Nhãn đội xử lý, severity, trường thông tin chính
Metric	Precision/recall theo nhãn quan trọng
Risk	Routing sai làm chậm xử lý incident nghiêm trọng
Human	Approve với severity cao; automate với ticket rủi ro thấp

Ví dụ Canvas: CV giám sát hạ tầng

Ô	Nội dung mẫu
Problem	Phát hiện thiết bị/hiện tượng bất thường từ ảnh kiểm tra
Data	Ảnh hiện trường, nhãn bbox, điều kiện ánh sáng khác nhau
AI task	Object detection
Tool	Pre-trained detector (YOLOv8+) + fine-tune sau nếu đủ dữ liệu
Output	Bbox, class, confidence, ảnh cần review
Metric	Precision/recall, false alarm, missed defect
Risk	Bỏ sót lỗi nghiêm trọng hoặc quá nhiều báo động giả
Human	Assist; người kiểm tra xác nhận trước khi tạo ticket

Kiến trúc PoC tối giản có kiểm soát



PoC không cần production đầy đủ, nhưng phải có evaluation và risk control.

Go / Pilot / Not yet

Go	Pilot	Not yet
Rủi ro thấp, metric đạt, dữ liệu ổn, guardrail rõ, hợp quy định.	Có giá trị nhưng cần thử phạm vi hẹp, người giám sát chặt.	Dữ liệu thiếu, rủi ro cao, chưa có owner hoặc metric chưa rõ.

Checklist trách nhiệm trước khi triển khai

- Có nói rõ vấn đề nghiệp vụ và baseline không?
- Có mô tả dữ liệu, phân loại và giới hạn pháp lý không?
- Có test case, metric và đo bias theo nhóm không?
- Có risk checklist (5 nhóm) và guardrail không?
- Có cách giải thích (XAI/grounding) và điểm human control không?
- Có kết luận Go / Pilot / Not yet không?

Mini activity: đánh giá rủi ro một use case

Chọn một use case

RAG sổ tay vận hành, phân loại alarm/ticket, CV giám sát hạ tầng, hoặc incident assistant.

1. Xếp use case vào mức rủi ro theo tinh thần EU AI Act.
2. Nêu 1 rủi ro cho mỗi nhóm: accuracy, bias, privacy, security, accountability.
3. Đề xuất 1 guardrail và 1 điểm human control.
4. Chốt mức tự động hóa phù hợp: Assist / Approve / Automate.

Câu hỏi debrief bắt buộc

1. Use case này có thể sai hoặc gây bất công cho nhóm nào?
2. Dữ liệu nào bị cấm/cần masking theo quy định Tập đoàn và pháp luật VN?
3. Làm sao giải thích quyết định của model cho người dùng/kiểm toán (SHAP/LIME/grounding)?
4. Ai chịu trách nhiệm cuối cùng và con người kiểm soát ở bước nào?

Tổng kết Bài 2 và cầu nối

- Responsible AI = AI **giải thích được, đo lường được, kiểm soát được** – theo nguyên tắc MS/Google và khung EU AI Act.
- XAI (SHAP, LIME) và grounding/citation giúp hiểu và kiểm tra quyết định của model.
- Bias phải được đo theo nhóm và giảm thiểu, không chỉ nhìn accuracy tổng thể.
- Bảo mật dữ liệu khách hàng: tuân thủ quy định Tập đoàn và pháp luật VN (Nghị định 13/2023, Luật ANM, Luật ATTT mạng).
- AI Risk Assessment (Govern–Map–Measure–Manage) là khung xuyên suốt cho mọi use case ở Bài 3–8.

Bài 3

Bắt đầu thực hành: **Prompt Engineering, gọi API LLM nội bộ (Viettel AI Platform) và Hugging Face Hub**.